Problem Analysis and Feasibility Study

LexCorp: Secure Identity, Access Control and Asset Custody Platform

1 Introduction

1.1 Purpose of this Document

This document records the problem analysis and the feasibility study carried out for **LexCorp**, a platform for secure identity management, access control and custody of sensitive documents and equipment. It explains the problem in detail, identifies the people affected by it, compares possible solutions, and evaluates whether the chosen solution is technically, economically, operationally, legally and schedule-wise feasible. It ends with the proposed system architecture and a recommendation. The companion document, the Software Requirements Specification (SRS), builds on this analysis.

1.2 Project Overview

Organisations that handle sensitive records (defence and research units, public-sector undertakings, government departments, banks and large enterprises) must control who can see, change or share each document and device, and must be able to prove it later. LexCorp gives every employee a self-owned digital identity, enforces permissions through a smart contract on a private (permissioned) blockchain, records every document and device as a unique token (NFT), issues a traceable watermarked copy for every view, and keeps an audit trail that cannot be edited. A locally hosted machine-learning model flags unusual behaviour, and people decide what to do about it.

1.3 Scope of the Study

- Analysis of the current way sensitive records and equipment are handled, and of its weaknesses.
- Identification of stakeholders, their needs and the root causes of the problem.
- Comparison of alternative solutions and selection of the proposed approach.
- Technical, economic, operational, schedule and legal feasibility of the proposed approach.
- Risk analysis and the high-level system architecture.

1.4 Method of Study

The study combined (a) a review of how organisations typically manage identities, documents and assets today; (b) a review of relevant standards and guidance (W3C Decentralized Identifiers, ERC-721, NIST SP 800-63B, NIST SP 800-207, the Digital Personal Data Protection Act 2023 and CERT-In directions); (c) a comparison with existing commercial and open-source products; and (d) building and testing an early working prototype to confirm that the key technologies work together.

2 Problem Analysis

2.1 Background

Sensitive organisations run on documents (designs, reports, contracts, orders) and on physical equipment (laptops, test instruments, network devices). Both must be issued to the right

people, tracked through their life, and accounted for during audits. Cyber attacks on such organisations increasingly target people and processes rather than only networks: phishing steals passwords, insiders copy files, and attackers who gain administrator rights can change records and delete the logs that would reveal them.

2.2 Problem Statement

Organisations do not have a single, trustworthy system that proves who each person is, what they are allowed to do, who holds each document and device, and what happened to each of them. Identities depend on passwords and a central administrator, records and logs can be edited, leaked copies cannot be traced to their source, and misuse is usually discovered long after the damage is done.

2.3 Existing System and its Limitations

In the typical current setup, identity, documents, equipment and audit are handled by separate tools that do not trust or check each other. Table 1 summarises the present practice and its limitations.

Table 1: *Existing system and its limitations*

Area	Current practice	Limitation
Identity and sign-in	Central user directory; username and password, sometimes an OTP	Passwords are phished or shared; whoever controls the directory controls every identity
Access control	Permissions stored as flags in an application database	An administrator or attacker with database access can grant themselves any right
Documents	Shared drives, e-mail attachments, printed copies	No record of which copy went to whom; a leaked copy cannot be traced; edits go unnoticed
Equipment	Spreadsheets or an asset register in a central database	Entries can be changed silently; duplicate or fake records are hard to detect
Approvals	E-mail or verbal approval, sometimes a signed form	No reliable proof of who approved what; self-approval is possible
Audit and monitoring	Application logs reviewed manually after an incident	Logs can be edited or deleted; misuse is found late, if at all
Remote work	Application exposed on the internet or a shared VPN password	Internet exposure and shared credentials widen the attack surface

2.4 Stakeholder Analysis

Table 2: *Stakeholders and their needs*

Stakeholder	Interest in the system	Key needs
Employees (Users)	Submit, view and share documents in daily work	Simple passwordless sign-in; quick access to what they are allowed to see
Managers	Approve documents, devices, downloads and sharing for their departments	Clear approval queue; confidence that approvals are recorded and cannot be forged
Auditors	Investigate activity and review security alerts	Complete, tamper-proof history; risk levels; searchable trail
Administrators	Manage identities, roles and departments; final decision on alerts	One-step grant and revoke that takes effect everywhere; no single point of abuse
Organisation management	Protect sensitive information and prove compliance	Low cost; data kept on premises; evidence for regulators
External verifiers	Check whether a printed copy or device label is genuine	Scan a QR code and get an answer without an account

2.5 Root-Cause Analysis

Figure 1 groups the causes of the problem under people, process, technology and environment (an Ishikawa-style cause-and-effect view). The common thread is that trust is placed in a single editable database and a single powerful administrator, and that copies leave the system without any identity attached to them.

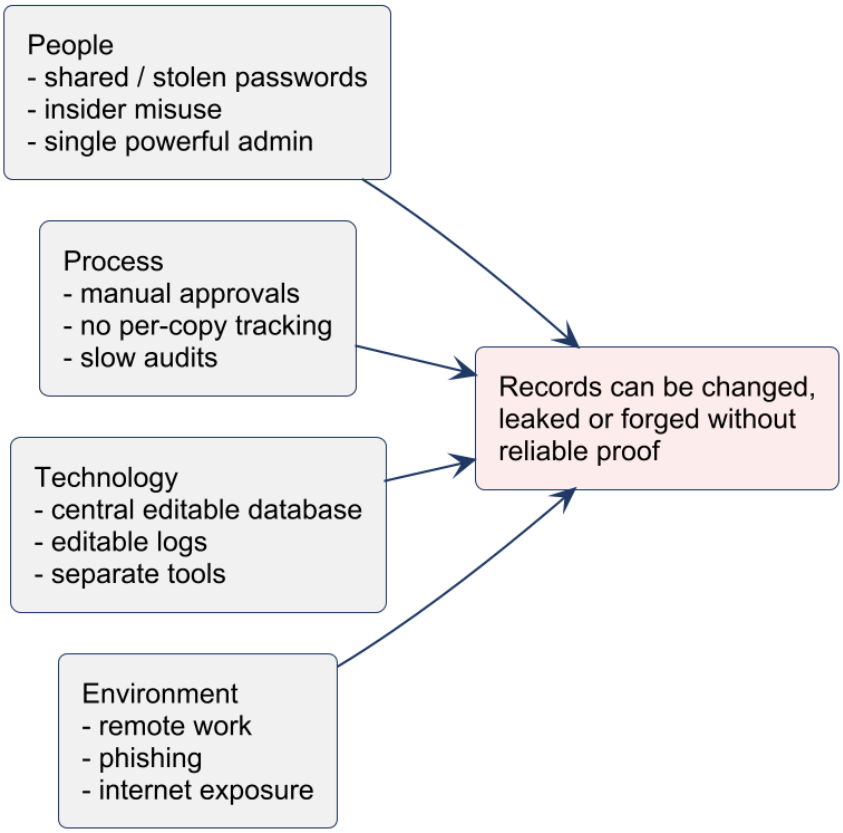


Figure 1: *Cause-and-effect analysis of the problem*

2.6 Threat Analysis

Table 3: *Threats the system must address*

Threat	Impact	What the solution must provide
Phishing and password theft	Attacker signs in as an employee	No passwords; phishing-resistant passkeys bound to the real site
Replay of a captured code or token	Repeated unauthorised actions	Single-use, short-lived proofs bound to one action
Compromised server or rogue administrator	Forged ownership records and permissions	Permissions enforced by a smart contract; the server key cannot create assets
Insider leak of a document	Loss of sensitive information	Every copy carries the viewer's identity and a verifiable QR code
Forged or edited copy	False documents accepted as genuine	SHA-256 fingerprint and an automatic check of returned copies
Log tampering	Evidence destroyed	Append-only audit table and cross-check against the blockchain
Session hijacking and account sharing	Actions performed under someone else's name	One session per account, bound to the network address, short idle timeout
Exposure of the application to the internet	Direct attacks from anywhere	No public port; VPN with company sign-in at every connection

2.7 Objectives

1. Give every employee a self-owned cryptographic identity whose private key never leaves their own device.
2. Replace passwords with passkeys and authenticator codes, and require a separate single-use proof for every sensitive action.
3. Enforce roles and asset ownership through a smart contract so that no server or single administrator can forge them.
4. Record every approved document and device as a unique token bound to its owner, with a SHA-256 fingerprint.
5. Make every issued copy traceable to the person who received it and verifiable by anyone.
6. Keep a complete, tamper-proof audit trail and detect misuse early with an explainable, locally hosted AI model.
7. Run fully on the organisation's own infrastructure using open-source software, with no licence or transaction fees.

2.8 Scope of the Proposed System

Table 4: *Scope of the proposed system*

In scope	Out of scope (current version)
Identity registration, provisioning, passkey and TOTP enrolment, sign-in, reset and revocation	Integration with an organisation's HR or payroll system
Role-based access control by role and department	Hardware security modules for server keys
Document registration, approval, minting, versioning, viewing, sharing and download	Mobile native applications (the web app is responsive instead)
Physical device registration, custody, QR labels and maintenance records	Public blockchain deployment
Watermarking and tamper detection of copies	Automatic action by the AI without human approval
Audit trail, risk scoring, alert escalation	
Remote access through a VPN with company sign-in	

2.9 Alternative Solutions Considered

Four alternatives were compared against the objectives in Section 2.7. Table 5 shows the evaluation (✓ meets the objective, ~ partly, ✗ does not).

Table 5: *Evaluation of alternative solutions*

Objective	A. Keep current tools	B. Buy commercial IAM + DRM + asset tools	C. Public blockchain application	D. Proposed permissioned platform
Self-owned identity	✗	~	✓	✓
Passwordless, per-action proof	✗	~ (premium licences)	✗	✓
Permissions no admin can bypass	✗	✗	✓	✓
Traceable, verifiable copies	✗	~	✗	✓
Tamper-proof audit	✗	~	✓	✓
Explainable misuse detection	✗	~ (premium licences)	✗	✓
Data stays on premises, no fees	✓	✗ (per-user licences)	✗ (gas fees, public data)	✓

Alternative A leaves the problem unsolved. Alternative B addresses parts of it but depends on several separate products, recurring per-user licences and cloud services, and still trusts a central administrator. Alternative C gives tamper-proof records but exposes data on a public network and charges a fee for every transaction. **Alternative D, a permissioned blockchain platform run by the organisation itself, meets all objectives and is selected.**

2.10 Proposed Solution Overview

Figure 2 shows the proposed system in its environment. Employees and external verifiers interact with the LexCorp platform; the platform relies on a permissioned blockchain for ownership and permissions, on authenticator apps and passkey devices for proof of identity, and on the company sign-in service at the VPN gateway for remote access.

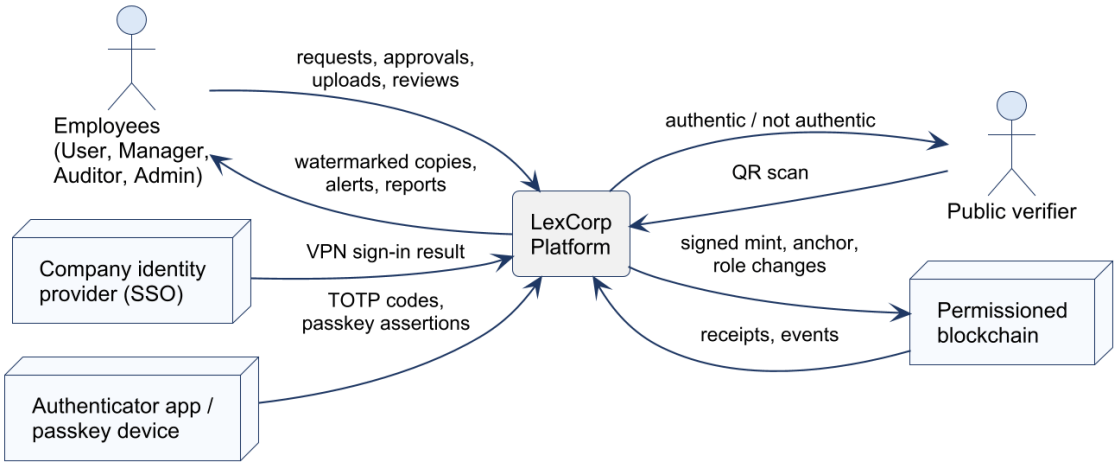


Figure 2: *Context of the proposed system*

3 Feasibility Study

The feasibility study checks whether the proposed system can and should be built, from five points of view.

3.1 Technical Feasibility

All required technologies are mature, open source and widely used. The team already has working experience with them through the prototype. Table 6 lists the main technology choices.

Table 6: *Technology choices*

Need	Technology	Maturity / reason for choice
Permissioned blockchain	Hyperledger Besu with QBFT consensus	Enterprise Ethereum client; fast finality, zero gas price, private network
Smart contract	Solidity + OpenZeppelin (ERC-721, AccessControl)	Industry-standard audited libraries for tokens and roles
Identity	Ethereum wallet (ethers.js), W3C DID (did:ethr)	Key generated and kept in the user's browser
Authentication	WebAuthn / FIDO2 passkeys, TOTP (RFC 6238)	Phishing-resistant; supported by all modern browsers and phones
Backend	Python, FastAPI, SQLAlchemy, web3.py	Asynchronous, typed, well documented
Database	PostgreSQL	Reliable relational store; triggers enforce append-only audit
Frontend	React + Vite	Responsive single-page application
Documents	ReportLab, pypdf, python-docx, python-pptx, OpenCV	Watermarking of all common formats; QR decoding for tamper checks
Machine learning	scikit-learn (IsolationForest, gradient boosting)	Runs locally on a CPU; no data sent to external AI services
Remote access	OpenVPN with OpenID Connect sign-in, WireGuard, Caddy (TLS)	Company sign-in at every connection; application never exposed publicly
Deployment	Docker	Same setup on a laptop, a server or an air-gapped network

Evidence from the prototype. An early working prototype confirms that the pieces work together: 278 automated backend tests and 23 smart-contract tests pass; three tests on the live blockchain show that a mint from an unauthorised wallet is rejected by the contract itself; thirteen end-to-end browser flows pass on desktop, tablet and phone; and the risk model reaches a ranking score (ROC AUC) of 0.992 on simulated staff activity.

Hardware. A single server with 8 CPU cores, 32 GB RAM and 1 TB SSD is sufficient for a pilot (the three blockchain validators, the database and the application run as containers). The VPN gateway needs only a small virtual machine. **Conclusion: technically feasible.**

3.2 Economic Feasibility

Development cost (Basic COCOMO). The prototype contains about 14.8 thousand lines of production code (backend, frontend, smart contract, machine-learning and deployment scripts, excluding tests). Because the system combines security, cryptography and a blockchain, it is classed as a *semi-detached* project (a = 3.0, b = 1.12, c = 2.5, d = 0.35).

Table 7: *Basic COCOMO estimate of development effort and cost*

Quantity	Formula	Result
Effort	E = 3.0 × (14.8)^1.12	61.3 person-months
Development time	D = 2.5 × E^0.35	10.6 months
Average team size	E / D	5.8 persons
Development cost	E × ₹50,000 per person-month	≈ ₹30.7 lakh (one-time)

This is the estimated cost if the system were built commercially; as a student project the actual monetary cost is limited to hardware and hosting.

Table 8: *Operating cost estimate*

Item	Estimated cost (₹)	Type
Pilot server (8 cores, 32 GB RAM, 1 TB SSD)	150,000	one-time
UPS and network equipment	30,000	one-time
VPN gateway virtual machine	12,000	per year
Domain name and TLS certificates	0	per year (free options)
Software licences (all open source)	0	none
Maintenance (0.5 person)	300,000	per year

Cost of the main alternative. For 500 employees, licences for a commercial identity product (Microsoft Entra ID P2, US$10 per user per month) and a document-protection product (Microsoft Purview Suite, US$12 per user per month) cost about **₹1.27 crore per year** at ₹96 per US$, before any asset-management tool. These figures are list prices (September 2026) and cover licences only.

Cost–benefit. The proposed system needs about ₹32.5 lakh once (development plus hardware) and about ₹3.1 lakh per year to run, while avoiding about ₹127 lakh per year in licences. The one-time cost is therefore recovered in roughly **3 months** of avoided licence fees. There are also benefits that are hard to price: faster audits, fewer leaks, and evidence that stands up in an investigation. **Conclusion: economically feasible.**

3.3 Operational Feasibility

- **Fits existing work.** Employees keep their usual activities (submit, approve, view, share); the system adds proof around them rather than new jobs.
- **Easy to use.** Sign-in uses a fingerprint, face or PIN on the user's own device (passkey) or an authenticator app, which staff already use for other services. No cryptocurrency or blockchain knowledge is needed; the wallet is created in the browser.
- **Roles match the organisation.** User, Manager, Auditor and Administrator mirror existing responsibilities, and managers see only their own departments.

- **People stay in control.** The AI only advises; alerts go to an Auditor, then a Manager, then an Administrator.
- **Training.** A one-hour session per role and a short user guide are enough; administrators need a half-day session on identity management and alert handling.
- **Resistance.** Extra confirmation steps may feel slower; this is reduced by letting users choose to confirm routine actions with their login factors and by keeping each step to a single tap.

Conclusion: operationally feasible.

3.4 Schedule Feasibility

The project follows the **incremental model**: the requirements are well understood, but the system is large, so it is delivered in three working increments (identity, assets and blockchain, then copies, sharing, audit and AI), each designed, built and tested before the next. This gives early working software and lets risks be handled per increment. Figure 3 shows the 16-week plan.

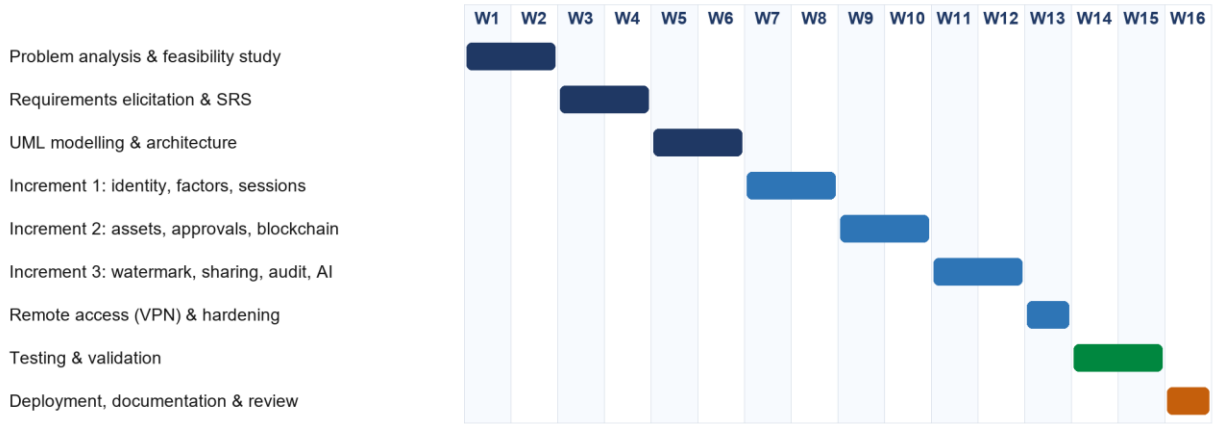


Figure 3: *Project schedule (16 weeks, incremental model)*

The critical path runs through the three increments. One week of slack is kept in the testing phase. Because a working prototype already covers the core features, the plan is achievable within a semester. **Conclusion: feasible within the schedule.**

3.5 Legal and Ethical Feasibility

- **Digital Personal Data Protection Act, 2023.** Personal data (names, contact details, files) is stored only off-chain in the organisation's database, where it can be corrected or deleted; the blockchain holds only hashes, token numbers and pseudonymous identifiers.
- **Information Technology Act, 2000.** Records are kept with integrity and access control; every action is attributable to an identified person.
- **CERT-In Directions (April 2022).** The audit trail keeps security logs for at least 180 days and supports incident reporting.
- **Software licences.** All components are open source under permissive licences (Apache 2.0, MIT, BSD) that allow internal use.

- **Ethics.** Watermarks and monitoring apply only to work documents inside the system; employees are told that activity is recorded; the AI cannot take action on its own, in line with the software engineering code of ethics (public interest, client and employer, product quality).

Conclusion: legally and ethically feasible.

3.6 Risk Analysis

Table 9: *Risk analysis*

Risk	Likelihood	Impact	Mitigation
User loses device or authenticator	Medium	Medium	Several passkeys per person; administrator-approved reset with a new one-time PIN
Server key stolen	Low	High	Server key can only grant roles, never mint; keys rotatable; indexer flags unapproved mints
Validator node failure	Medium	Medium	QBFT tolerates faults with four or more validators across sites; regular backups
AI false alarms	Medium	Low	Fixed low false-alert rate; one alert per incident; human review
No real insider-attack data for training	High	Medium	Simulated scenarios; rules remain primary; retrain on reviewed alerts
Users find extra steps slow	Medium	Low	Passkeys (one tap); optional use of login factors for routine actions
Schedule slip in an increment	Medium	Medium	Incremental delivery; slack in the testing phase; scope moved to a later version

4 System Architecture

4.1 Architectural Style

LexCorp uses a **layered client–server architecture** with a **blockchain trust layer**. Each layer depends only on the layer below it, which keeps concerns separate: the access layer decides who can reach the system, the presentation layer runs in the browser (and holds the user's wallet), the application layer applies the business rules, and the data and trust layer stores records and enforces ownership and permissions independently of the server. Figure 4 shows the layers and their components.

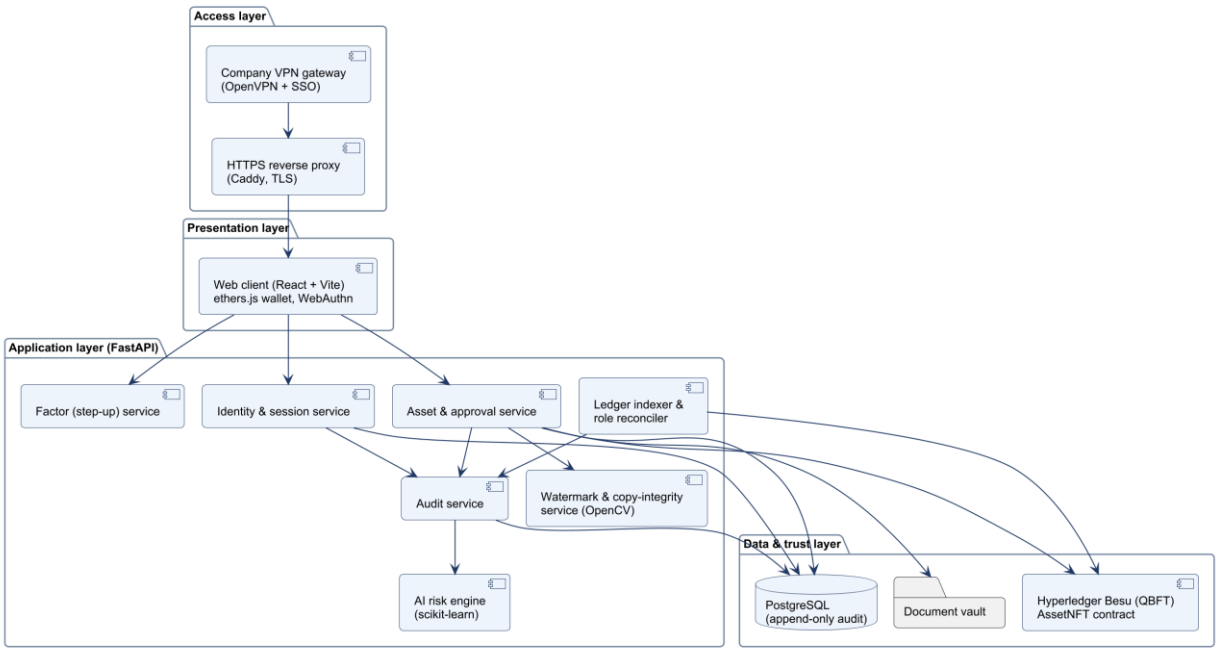


Figure 4: *Layered architecture of LexCorp*

4.2 Component Description

Table 10: *Architecture components*

Component	Responsibility
Company VPN gateway	Admits remote staff only after company sign-in at every connection; gives each connection its own address
HTTPS reverse proxy	Terminates TLS and forwards requests to the application; the only entry point
Web client	User interface; creates and keeps the wallet keystore; performs passkey ceremonies; signs mint transactions
Identity & session service	Registration, provisioning, sign-in, one session per account, idle timeout, revocation
Factor (step-up) service	Issues and consumes single-use proofs for Factor 2 and Factor 3 actions
Asset & approval service	Documents and devices: submission, approval, minting, versions, sharing, downloads
Watermark & copy-integrity service	Generates watermarked copies; decodes QR codes with OpenCV and checks returned copies
Audit service	Writes every event with actor, role, address and risk level to the append-only audit table
AI risk engine	Scores events against each person's history and explains the score in plain words
Ledger indexer & role reconciler	Reads contract events, cross-checks them with the database, keeps on-chain roles in step
PostgreSQL and document vault	Off-chain records, personal data and files
Hyperledger Besu + AssetNFT contract	Ownership tokens, file hashes, versions and role checks

4.3 Deployment View

Figure 5 shows where the components run. The application, database and the three blockchain validators run on the organisation's own server; office users reach it over the office network, and remote users only through the VPN gateway, which connects to the office over an encrypted WireGuard link.

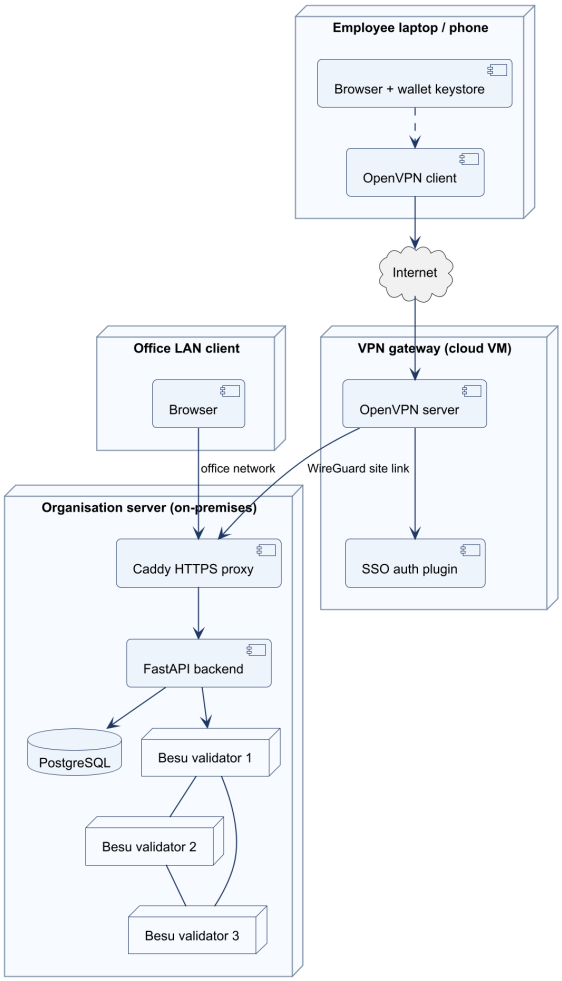


Figure 5: *Deployment diagram*

4.4 Key Design Decisions

- **Private keys never leave the user's device**, so a server breach does not expose identities.
- **Permissions are checked twice**: by the application and by the smart contract; the interface hiding a button is never relied on for security.
- **Only hashes go on-chain**; files and personal data stay off-chain, which keeps the ledger small and respects data-protection law.
- **Approvals are signed by the approving officer's own wallet**, so the ledger proves which person approved each asset.
- **The AI is advisory** and runs locally; people make every decision.

5 Conclusion and Recommendation

The analysis shows that the current approach cannot prove who did what with sensitive records, and that the root causes are central trust, editable records and untraceable copies. The proposed permissioned-blockchain platform addresses every identified threat, is built from mature open-source technology, pays back its cost within months compared with commercial licences, fits existing roles and workflows, complies with Indian data-protection and cyber-security rules, and can be delivered within one semester using the incremental model. **It is recommended that development proceed**, with the detailed requirements captured in the Software Requirements Specification.

6 References

[1] R. S. Pressman, *Software Engineering: A Practitioner's Approach*, 7th ed., McGraw-Hill, 2017.

[2] I. Sommerville, *Software Engineering*, 10th ed., Pearson, 2016.

[3] B. W. Boehm, *Software Engineering Economics*, Prentice Hall, 1981 (COCOMO).

[4] W3C, *Decentralized Identifiers (DIDs) v1.0*, W3C Recommendation, 2022. https://www.w3.org/TR/did-core/

[5] W. Entriken et al., *EIP-721: Non-Fungible Token Standard*, Ethereum Improvement Proposals, 2018. https://eips.ethereum.org/EIPS/eip-721

[6] Hyperledger Besu documentation, *QBFT consensus*. https://besu.hyperledger.org/private-networks/how-to/configure/consensus/qbft

[7] NIST, *SP 800-63B-4: Digital Identity Guidelines, Authentication*, 2025. https://csrc.nist.gov/pubs/sp/800/63/b/4/final

[8] NIST, *SP 800-207: Zero Trust Architecture*, 2020. https://csrc.nist.gov/pubs/sp/800/207/final

[9] W3C, *Web Authentication: An API for accessing Public Key Credentials, Level 2*, 2021. https://www.w3.org/TR/webauthn-2/

[10] F. T. Liu, K. M. Ting and Z.-H. Zhou, "Isolation Forest," *Proc. IEEE ICDM*, 2008. https://doi.org/10.1109/ICDM.2008.17

[11] Government of India, *Digital Personal Data Protection Act, 2023*. https://www.meity.gov.in/data-protection-framework

[12] CERT-In, *Directions under sub-section (6) of section 70B of the IT Act, 2000*, April 2022. https://www.cert-in.org.in/Directions70B.jsp

[13] Microsoft, *Microsoft Entra plans and pricing* and *Microsoft Purview pricing*, accessed September 2026.